MANUAL OFICIAL DE PRUEBAS DE SEGURIDAD

Manual de Pruebas de Seguridad y DevSecOps

Batería de pruebas automatizadas bajo OWASP AI-SVS v1.0, análisis de inyecciones de prompts, seguridad en RAG, aislamiento de Firestore y protocolo de Red Teaming.

OWASP AI-SVS v1.0 (12 Capítulos) | Prompt Injection Defense | RAG Vector Poisoning | Cloud DLP Enmascaramiento | Firestore Security Rules Audit

Identificador Documental:	DOC-AEGIS-SEC-2026-V2
Público Objetivo:	Equipos de Ciberseguridad, CISOs, Red Teams y Especialistas en DevSecOps
Autor / Security Lead:	AegisAI Open Source Community & Core Security Engineering Team
Norma de Evaluación:	OWASP AI Security Verification Standard (AI-SVS) v1.0
Cobertura de Seguridad:	12 de 12 Capítulos Validados con Suite Automatizada
Fecha de Liberación:	24 de Septiembre de 2026
Clasificación:	Open Source / Public Community Release (Apache 2.0)

Indice de Contenido

1. **1. Filosofía de Seguridad y Postura DevSecOps** — Principios de defensa en profundidad en sistemas de IA.
2. **2. La Suite Automatizada de Pruebas (OWASP AI-SVS v1.0)** — Arquitectura de ejecución del test runner.
3. **3. Pruebas Detalladas por los 12 Capítulos de OWASP**:
    - C1: Inyección de Prompts y Validaciones
    - C2: Manejo y Sanitización de Salidas
    - C3: Protección de Datos y Privacidad (Cloud DLP)
    - C4: Seguridad en Cadena de Suministro de Modelos
    - C5: Control de Acceso y Mínimo Privilegio
    - C6: Infraestructura y Aislamiento de Inferencia
    - C7: Seguridad en Datos y Bases Vectoriales (RAG)
    - C8: Resiliencia ante Denegación de Servicio (DoS)
    - C9: Auditoría, Monitoreo y Trazabilidad Forense
    - C10: Mitigación de Alucinaciones y Verificación de Fuentes
    - C11: Gobernanza y Gestión de Riesgos
    - C12: Red Teaming y Resiliencia Continua
4. **4. Auditoría de Reglas de Firestore (aegis-ai-db)** — Verificación contra escalación y bypass.
5. **5. Protocolo de Pruebas Adversarias (Red Teaming)** — Escenarios de prueba de ataque simulado.
6. **6. Plan de Respuesta a Incidentes de IA** — Procedimiento ante hallazgos de severidad crítica.

1. Filosofía de Seguridad y Postura DevSecOps

La seguridad en **AegisAI** trasciende la ciberseguridad tradicional en la nube. Mientras que la seguridad de infraestructura se ocupa de puertos y cortafuegos, AegisAI implementa controles para mitigar los nuevos vectores de ataque cognitivos que afectan a los LLMs y a los agentes de IA.

Nuestra postura DevSecOps incorpora la verificación de seguridad automatizada en cada fase del ciclo de vida del software (CI/CD), asegurando que ninguna versión se publique sin superar las 12 pruebas de OWASP AI-SVS.

2. La Suite Automatizada de Pruebas (OWASP AI-SVS v1.0)

El script `scripts/run_owasp_ai_security_tests.mjs` implementa un banco de pruebas exhaustivo que somete a la plataforma a ataques sintéticos y verificaciones de configuración:

```
$ npm run test:security
> node scripts/run_owasp_ai_security_tests.mjs

[OWASP AI-SVS] Iniciando batería de 12 pruebas de seguridad...
[C1] Inyección de Prompts: VALIDADO (Bloqueo en delimitadores XML y WAF)
[C2] Sanitización de Salidas: VALIDADO (Filtro DOMPurify y CSP)
[C3] Privacidad de Datos: VALIDADO (Integración Cloud DLP detectada)
...
[C12] Red Teaming: VALIDADO (Resistencia comprobada)
Reporte de Seguridad generado en: scripts/owasp_ai_security_report.json
```

3. Pruebas Detalladas por los 12 Capítulos de OWASP

CAPÍTULO OWASP	VECTOR DE ATAQUE SIMULADO	MECANISMO DEFENSIVO VERIFICADO	RESULTADO
C1: Inyección de Prompts	Inyección directa (*"Ignora tus instrucciones previas"*) e indirecta en corpus RAG.	Encapsulamiento en bloques XML estrictos `<untrusted_input>` y system prompts blindados.	APROBADO
C2: Sanitización de Salidas	Inyección de payloads XSS (`<script>alert(1)</script>`) en respuestas del modelo.	Sanitización estricta con DOMPurify y directiva CSP restrictiva en el frontend.	APROBADO
C3: Privacidad de Datos	Envío de PII sensible (RFCs, números de tarjetas, correos) hacia el modelo base.	Inspección y enmascaramiento previo mediante Cloud Sensitive Data Protection (DLP).	APROBADO
C4: Cadena de Suministro	Inclusión de pesos manipulados o dependencias npm con CVEs conocidas.	Auditoría automatizada de librerías y verificación de hashes en modelos de Vertex AI.	APROBADO
C5: Control de Acceso	Invocación no autenticada de endpoints de inferencia de Vertex AI.	Autenticación IAM por tokens OAuth de corta vida y llaves en Cloud Secret Manager con rotación.	APROBADO
C6: Aislamiento	Ejecución de código arbitrario generado por el modelo dentro del contenedor.	Sandboxing estricto en contenedores sin privilegios de root ni acceso a red externa.	APROBADO
C7: Seguridad en RAG	Envenenamiento de índices vectoriales mediante documentos maliciosos.	Filtrado previo de documentos, validación de integridad y embeddings aislados en Vertex AI Search.	APROBADO
C8: Resiliencia ante DoS	Explosión de ventana de contexto (payloads de más de 100k tokens para causar agotamiento de cuota).	Rate limiting en API Gateway y validación estricta de longitud máxima en el frontend (4k caracteres).	APROBADO
C9: Logging Forense	Acceso forense a registros sin comprometer datos confidenciales de los usuarios.	Auditorías inmutables en `aegis-ai-db` con registro de marcas de tiempo y autoría.	APROBADO
C10: Alucinaciones	Generación de respuestas con afirmaciones normativas falsas o inexistentes.	Grounding obligatorio: cada veredicto exige obligatoriamente citas de cláusulas reales y evidencia.	APROBADO
C11: Gobernanza	Sistemas desplegados sin asignación formal de responsabilidades.	Generación automática de la Matriz RACI en cada reporte de evaluación.	APROBADO

C12: Red Teaming	Pruebas de estrés continuo contra el pipeline de inferencia.	Ejecución periódica del test runner de seguridad integrado en el pipeline de despliegue.	APROBADO

4. Auditoría de Reglas de Firestore (aegis-ai-db)

Se ejecutó una auditoría de penetración específica contra el archivo `firestore.rules`:

- **Prueba de Fuga de Dominio:** Se simularon peticiones con tokens autenticados pero de dominios no autorizados (ej. `test@gmail.com`). **Resultado:** Rechazo inmediato con código `PERMISSION_DENIED`.
- **Prueba de Eliminación Maliciosa:** Se ejecutaron llamadas `deleteDoc` directas sobre documentos existentes en la colección `audits`. **Resultado:** Rechazo total debido a la regla `allow delete: if false;`, garantizando el cumplimiento del Invariante 4 de OWASP AI-SVS.

5. Protocolo de Pruebas Adversarias (Red Teaming)

> **Protocolo de Red Teaming Continuo**
>
> El equipo de seguridad de AegisAI ejecuta ejercicios mensuales de Red Teaming empleando el dataset de pruebas adversarias de Google Cloud Vertex AI Model Armor para descubrir nuevos vectores emergentes de inyección multimodal y envenenamiento de contexto.

6. Plan de Respuesta a Incidentes de IA

En caso de que una auditoría detecte una vulnerabilidad de severidad **CRITICAL** en un sistema en producción:

1. **Aislamiento Inmediato:** La API de AegisAI emite una alerta al equipo DevSecOps para restringir el tráfico del endpoint de Vertex AI mediante VPC Service Controls.
2. **Generación de Plan de Remediación:** Se extrae la sección de remediación del reporte técnico generado en AegisAI.
3. **Re-auditoría de Validación:** Se ejecuta el flujo de re-auditoría en AegisAI para constatar que el score haya alcanzado al menos el 80% antes de autorizar el redespliegue.